

# Rails Health Audit — example-unhealthy-project

Generated 2026-06-23 14:25. Phase 1 (static scan). Full raw tool output is in `raw_original_result/`.

## 1. Overview (every check, most severe first)

| Priority | Category          | Tool                 | Finding                    | Raw output                                                |
|----------|-------------------|----------------------|----------------------------|-----------------------------------------------------------|
| 🔴 1      | Security          | brakeman             | 4 warning(s)               | <code>raw_original_result/brakeman.txt</code>             |
| 🔴 1      | Security          | bundler-audit        | 8 vulnerable advisory(ies) | <code>raw_original_result/bundler-audit.txt</code>        |
| 🔴 1      | Compliance        | license_finder       | 73                         | <code>raw_original_result/license_finder.txt</code>       |
| 🟡 3      | Performance       | fasterer             | 5 speed suggestion(s)      | <code>raw_original_result/fasterer.txt</code>             |
| 🟡 4      | Maintainability   | rubycritic           | score 93.97, 29 smell(s)   | <code>raw_original_result/rubycritic.txt</code>           |
| 🟡 4      | Rails conventions | rails_best_practices | 15 warning(s)              | <code>raw_original_result/rails_best_practices.txt</code> |
| ⚪ 4      | Maintainability   | rubocop              | 23 offense(s)              | <code>raw_original_result/rubocop.txt</code>              |
| ⚪ 4      | Maintainability   | erb_lint             | 8 ERB offense(s)           | <code>raw_original_result/erb_lint.txt</code>             |
| ⚪ 5      | Tech debt         | bundle outdated      | 2                          | <code>raw_original_result/outdated.txt</code>             |

Legend — 🔴 must fix (security / data) · 🟡 should fix (correctness / maintainability) · ⚪ nice to have (style / freshness).

A  **skipped check is NOT a pass.** It means the tool could not run in this environment, not that there is nothing wrong. `license_finder` needs a real `bundle install`; `bundle outdated` needs the project's own Ruby (this run used a different Ruby than the project pins). Re-run both in the project's environment to get a real result. *(In this example both ran — it is a real, bundle-installed Rails 8 app — so neither is skipped.)*

## 2. Action plan

**How to read this — cut noise with confidence/criticality:** static tools over-report. brakeman tags each warning High / Medium / Weak confidence — fix the **High** ones first; Weak ones are often false positives. bundler-audit tags each advisory Critical / High / Medium — triage **Critical/High**, don't treat all 100+ as equal. So a raw count (e.g. "137 advisories") is a starting point, not 137 separate jobs.

Severity first. Cover every  and  finding (one row each); collapse the  style-level findings into a single row. Use `<br>` for line breaks inside a cell.

| # | Pr<br>i                                                                             | Issue (tool, file:line )                                                                                                                                                                                                                     | Solution                                                                                                                                                            | Ef<br>fo<br>rt | Raw                                                          |
|---|-------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------|--------------------------------------------------------------|
| 1 |  | <b>Command injection</b><br>(brakeman, High)<br><code>app/controllers/products_c<br/>ontroller.rb:28</code> — <code>system</code><br>( <code>"convert #{thumb} ..."</code> )<br>shells out with user input.                                  | Never interpolate params into a<br>shell. Use an image library ( <code>im<br/>age_processing / vips</code> ) or<br>pass args as an array so no<br>shell is invoked. | M              | <code>raw_origin<br/>al_result/b<br/>rakeman.tx<br/>t</code> |
| 2 |  | <b>SQL injection</b> (brakeman,<br>High)<br><code>app/controllers/products_c<br/>ontroller.rb:8</code> ( <code>where("... #<br/>{params[:q]} ..."</code> ) and <code>:10</code><br>( <code>connection.execute</code> with<br>interpolation). | Parameterize: <code>where("name LI<br/>KE ?", "%#{q}%")</code> ; <code>whitelist p<br/>arams[:sort]</code> against allowed<br>columns.                              | M              | <code>raw_origin<br/>al_result/b<br/>rakeman.tx<br/>t</code> |
| 3 |  | <b>XSS</b> (brakeman, High)<br><code>app/views/products/index.h</code>                                                                                                                                                                       | Drop <code>.html_safe</code> ; let Rails<br>auto-escape. If HTML is                                                                                                 | S              | <code>raw_origin<br/>al_result/b</code>                      |

| # | Pr<br>i | Issue (tool, file:line )                                                                                                                    | Solution                                                                                                        | Eff<br>ort | Raw                                                          |
|---|---------|---------------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------|------------|--------------------------------------------------------------|
|   |         | tml.erb:4 — params[:q].html_safe renders raw user input.                                                                                    | needed, sanitize an allow-list.                                                                                 |            | rakeman.txt                                                  |
| 4 | ●       | <b>Vulnerable gem: jwt 2.3.0</b><br>(bundler-audit, High)<br>CVE-2026-45363 — empty-key HMAC signature bypass.                              | Upgrade gem "jwt", ">= 3.2.0", then bundle update jwt.                                                          | S          | raw_origin<br>al_result/b<br>undler-audi<br>t.txt            |
| 5 | ●       | <b>Vulnerable gem: rexml 3.2.4</b><br>(bundler-audit, 7 advisories incl. High ReDoS GHSA-2rxp-v6pw-ch6m).                                   | Upgrade gem "rexml", ">= 3.3.9", then bundle update rexml. One bump clears all 7.                               | S          | raw_origin<br>al_result/b<br>undler-audi<br>t.txt            |
| 6 | ●       | <b>License compliance</b><br>(license_finder)<br>73 dependencies have no approval decision.                                                 | Set an allowed-license policy; approve/replace anything copyleft (GPL) that conflicts with the product license. | M          | raw_origin<br>al_result/l<br>icense_find<br>er.txt           |
| 7 | ●       | rescue Exception<br>(rails_best_practices)<br>app/controllers/products_controller.rb:35 swallows every error, incl. signals.                | Rescue StandardError (or a specific class) and re-raise / report the rest.                                      | S          | raw_origin<br>al_result/r<br>ails_best_p<br>ractices.tx<br>t |
| 8 | ●       | <b>Fat controller / logic in view</b><br>(rails_best_practices)<br>products_controller.rb:14, 41 (@product used >4x) and index.html.erb:13. | Move create/update body into a service or model method; move the view conditional into a model helper.          | M          | raw_origin<br>al_result/r<br>ails_best_p<br>ractices.tx<br>t |
| 9 | ●       | <b>Maintainability smells</b><br>(rubycritic, 29)<br>app/models/product.rb — Law of Demeter (owner.address.city), feature envy, complex #s. | Add delegations (delegate :city, to: :address); rename/extract #s; de-duplicate the create / update blocks.     | M          | raw_origin<br>al_result/r<br>ubycritic.t<br>xt               |

| #      | Pr<br>i | Issue (tool, file:line )                                                                                                                                 | Solution                                                                       | Ef<br>fo<br>rt | Raw                                                                                     |
|--------|---------|----------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------|----------------|-----------------------------------------------------------------------------------------|
| 1<br>0 | 🟡       | <b>Slow Ruby idioms</b> (fasterer, 5)<br>app/models/report.rb:6 ( select{}.first → detect ), :16<br>( reverse.each → reverse_eac<br>h ); plus config/* . | Swap to the faster idiom each<br>line names — trivial,<br>mechanical.          | S              | raw_origin<br>al_result/f<br>asterer.tx<br>t                                            |
| 1<br>1 | ⬜       | <b>Style</b> (rubocop 23 + erb_lint 8)<br>spacing, tag formatting, layout<br>across app/ .                                                               | Auto-fix: rubocop -A and erb<br>_lint --autocorrect , then<br>commit the diff. | S              | raw_origin<br>al_result/r<br>ubocop.txt<br>raw_origin<br>al_result/e<br>rb_lint.tx<br>t |

### 3. Phase 2 — runtime checks (follow-up, need app + DB)

These can't be answered by reading code; run them in the project (see audit-dynamic.sh):

- **Data correctness** — `active_record_doctor` (missing FKs, NOT NULL, unique indexes, model/DB mismatch)
- **Missing indexes** — `lol_dba` ( `db:find_indexes` )
- **N+1 queries** — `bullet` (dev/test) or `prosopite` ; exercise app / run tests
- **Test coverage** — `simplecov` → run the suite, read `coverage/index.html`